SC4063_NETWORK_SECURITY

COMPLETE

START: 14/04/2026 01:38:18 SYNC: 14/04/2026 04:52:01 ELAPSED 8h 04m 31s

49,165	2,355,2	117	8/4	138
ALERTS PROCESSED	ZEEK RECORDS MATCHED	PCAPS ANALYZED	GPT-4O WORKERS DONE	SQL QUERIES (GPT-4O)

4	71
FINDINGS	EVIDENCE ITEMS

GPT-4o Report | Claude Opus 4.6 Report | ⇩ Download PDF

Generated by GPT-4o (OpenAI)

LIVE MONITOR | FINDINGS | REPORTS 2 | TIMELINE | AGENT LOG | DB EXPLORER

Executive Summary

On March 1, 2025, SC4063 Network Security experienced a significant ransomware incident attributed to the Lynx group. The attack began with unauthorized access via a Remote Desktop Protocol (RDP) connection, leading to extensive lateral movement, data exfiltration, and eventual deployment of ransomware across the network. The incident resulted in the compromise of critical systems and potential exposure of sensitive data.

The severity of this incident is high, given the breadth of the attack and the sophistication of the techniques used. The attackers managed to infiltrate the network, exfiltrate data, and deploy ransomware, all while evading detection by existing security measures. Immediate action is required to mitigate further risks, including resetting credentials, removing direct RDP exposure, and blocking known exfiltration services.

To prevent future incidents, SC4063 Network Security should prioritize segmenting remote access, implementing privileged access management (PAM), and hardening backup access. Long-term measures should include deploying comprehensive monitoring solutions, strengthening credential hygiene, and restricting unnecessary protocol access.

Scope and Assumptions

The investigation was conducted using a 9-day packet capture (PCAP) from a core-switch tap. This network data was the sole source of evidence, as there was no endpoint telemetry or memory image available. Consequently, all conclusions are based on network traffic analysis, with inherent limitations in detecting endpoint-specific activities or memory-resident malware.

Detailed Findings

Finding A: Initial Access (T1133, T1078)

Confidence Level: High **Status:** Confirmed

A.1 RDP Access

The initial access was achieved via an RDP connection from the external IP `58.97.5.203` to the internal host `10.128.239.57` on March 1, 2025, at 18:23:58.914Z. This connection marked the beginning of the compromise, as evidenced by immediate LDAP queries to domain controllers for credential validation and domain enumeration. The RDP session did not trigger any alerts, indicating a stealthy approach by the attacker.

Key Evidence:

- **Timestamp:** 2025-03-01T18:23:58.914Z
- **Source IP:** 58.97.5.203
- **Destination IP:** 10.128.239.57
- **Protocol:** RDP
- **Description:** Initial RDP connection marking the start of the compromise.

A.2 Credential Spraying and Domain Enumeration

Following the RDP access, the attacker engaged in credential spraying and domain enumeration activities. LDAP queries were directed at the domain controller `10.128.239.29`, indicating attempts to validate credentials and enumerate domain resources.

Key Evidence:

- **Timestamp:** 2025-03-01T18:24:08.280Z
- **Source IP:** 10.128.239.57
- **Destination IP:** 10.128.239.29
- **Protocol:** LDAP
- **Description:** First LDAP connection indicating credential validation and domain enumeration.

A.3 Behavior Shift and Lateral Movement

Post-compromise, the attacker initiated 1,479 SMB operations targeting 135 distinct IPs, starting at 23:30:37.580Z. This activity included accessing administrative shares and staging executables, signaling lateral movement within the network.

Key Evidence:

- **Timestamp:** 2025-03-01T23:30:37.580Z
- **Source IP:** 10.128.239.57
- **Destination IPs:** Various
- **Protocol:** SMB
- **Description:** First occurrence of 'delete.me' probing, indicating post-compromise testing.

Limitations and Gaps:

- No alerts were triggered by the attacker IP, indicating stealthy access.

Finding B: Lateral Movement and Discovery (T1046, T1021.002, T1003.006, T1003, T1087.002, T1069.002, T1135, T1018, T1021.003)

Confidence Level: High **Status:** Confirmed

B.1 Internal RDP Pivoting

The attacker used the compromised host `10.128.239.57` to pivot within the network, initiating RDP connections to 98 unique internal hosts. The first RDP connection was to `10.128.239.64` on March 2, 2025, at 00:23:43.451Z.

Key Evidence:

- **Timestamp:** 2025-03-02T00:23:43.451Z
- **Source IP:** 10.128.239.57
- **Destination IP:** 10.128.239.64
- **Protocol:** RDP
- **Description:** First internal RDP connection from pivot host to target.

B.2 Credential Theft and DCSync Activity

Credential theft was confirmed with 5,947 DCSync calls from `10.128.239.21` to `10.128.239.23`, starting on March 6, 2025, at 22:41:51.038Z. This activity involved attempts to access DPAPI master keys via the `\\pipe\\lsass` named pipe.

Key Evidence:

- **Timestamp:** 2025-03-06T22:41:51.038Z
- **Source IP:** 10.128.239.57
- **Destination IP:** 10.128.239.23
- **Protocol:** DCERPC
- **Description:** bkrp_BackupKey operation indicating DPAPI master key theft attempt.

B.3 Backup File Access

The attacker accessed backup-related files on multiple hosts, including `Backup\\VeeamConfigBackup` on `10.128.239.39` and `Program Files\\Common Files\\Veeam` on `10.128.239.47`.

Key Evidence:

- **Timestamp:** 2025-03-06T23:04:53.418Z
- **Source IP:** 10.128.239.57
- **Destination IP:** 10.128.239.39
- **Protocol:** SMB
- **Description:** Access to Veeam backup configuration files.

Limitations and Gaps:

- NetBIOS hostname mappings were not found, limiting hostname resolution analysis.

Finding C: Exfiltration (T1567, T1560, T1039)

Confidence Level: High **Status:** Confirmed

C.1 DNS Queries and Data Upload

The internal host `10.128.239.57` made 46 DNS queries for the domain 'temp.sh', resolving to `51.91.79.17`, on March 6, 2025. This activity suggests an attempt to reach an exfiltration service. Significant upload activity was recorded, with 552,000,000 bytes (approximately 526.43 MB) uploaded in a single session.

Key Evidence:

- **Timestamp:** 2025-03-06T23:40:59.105Z

- **Source IP:** 10.128.239.57
- **Destination IP:** 51.91.79.17
- **Protocol:** DNS
- **Description:** DNS query for 'temp.sh' resolved to IP '51.91.79.17'.

C.2 File Access and Archive Staging

The attacker accessed 10,644 SMB files, including sensitive files such as backups and ZIP archives. Notable files include '1994_East_Maize_Lys_ClimDat.xlsx' and 'FEMA_Base_Flood_Elevations.zip'.

Key Evidence:

- **Timestamp:** 2025-03-06T23:11:03.956Z
- **Source IP:** 10.128.239.57
- **Destination IP:** 10.128.239.176
- **Protocol:** SMB
- **Description:** Accessed archive 'arrestees.zip'.

Limitations and Gaps:

- No alerts related to exfiltration or uploads were found.

Finding D: Payload Deployment (T1021.001, T1021.002, T1570, T1562.001, T1486)

Confidence Level: High **Status:** Confirmed

D.1 Executable Transfers and Security Tool Disabling

The internal host `10.128.239.57` was central to the deployment phase, transferring executables such as `UninstallWinClient.exe` on March 8, 2025, at 09:06:19.788Z, suggesting an attempt to disable security software.

Key Evidence:

- **Timestamp:** 2025-03-08T09:06:19.788Z
- **Source IP:** 10.128.239.57
- **Destination IP:** 10.128.239.66
- **Protocol:** SMB
- **Description:** Transfer of UninstallWinClient.exe, suggesting an attempt to disable security software.

D.2 Ransomware Staging and Deployment

The attacker initiated RDP connections to 95 distinct internal hosts and SMB connections to 87 distinct hosts post-March 7, 2025, indicating widespread deployment efforts.

Key Evidence:

- **Timestamp:** 2025-03-06T23:06:23.109Z
- **Source IP:** 10.128.239.57
- **Destination IP:** 10.128.239.36
- **Protocol:** SMB
- **Description:** Executable transfer alert for SETUP.EXE, indicating potential ransomware staging.

Limitations and Gaps:

- No direct evidence of an external attacker returning post-March 7, 2025.

Attack Timeline

TIMESTAMP	SOURCE → DESTINATION	PROTOCOL	DESCRIPTION
2025-03-01T18:23:58.914Z	58.97.5.203 → 10.128.239.57	RDP	Initial RDP connection marking the start of the compromise.
2025-03-01T18:24:08.280Z	10.128.239.57 → 10.128.239.29	LDAP	First LDAP connection indicating credential validation and domain enumeration.
2025-03-01T23:30:37.580Z	10.128.239.57 → Various	SMB	First occurrence of 'delete.me' probing, indicating post-compromise testing.
2025-03-02T00:23:43.451Z	10.128.239.57 → 10.128.239.64	RDP	First internal RDP connection from pivot host to target.
2025-03-06T22:41:51.038Z	10.128.239.57 → 10.128.239.23	DCERPC	bkrp_BackupKey operation indicating DPAPI master key theft attempt.
2025-03-06T23:04:53.418Z	10.128.239.57 → 10.128.239.39	SMB	Access to Veeam backup configuration files.
2025-03-06T23:40:59.105Z	10.128.239.57 → 51.91.79.17	DNS	DNS query for 'temp.sh' resolved to IP '51.91.79.17'.
2025-03-08T09:06:19.788Z	10.128.239.57 → 10.128.239.66	SMB	Transfer of UninstallWinClient.exe, suggesting an attempt to disable security software.

MITRE ATT&CK Mapping

FINDING	TECHNIQUE ID	TECHNIQUE NAME
A	T1133	External Remote Services
A	T1078	Valid Accounts
B	T1046	Network Service Scanning
B	T1021.002	SMB/Windows Admin Shares
B	T1003.006	DCSync
B	T1003	Credential Dumping
B	T1087.002	Domain Account
B	T1069.002	Domain Group
B	T1135	Network Share Discovery
B	T1018	Remote System Discovery
B	T1021.003	Distributed Component Object Model (DCOM)
C	T1567	Exfiltration Over Web Service
C	T1560	Archive Collected Data
C	T1039	Data from Network Shared Drive

D	T1021.001	Remote Desktop Protocol
D	T1021.002	SMB/Windows Admin Shares
D	T1570	Lateral Tool Transfer
D	T1562.001	Disable or Modify Tools
D	T1486	Data Encrypted for Impact

Indicators of Compromise (IOC) Summary Table

TYPE	VALUE	CONTEXT
IP Address	58.97.5.203	External attacker IP for initial RDP access
IP Address	51.91.79.17	Exfiltration service IP for 'temp.sh'
Domain	temp.sh	Domain used for data exfiltration
File	UninstallWinClient.exe	Executable used to disable security software
File	SETUP.EXE	Potential ransomware staging executable
File	ChromeSetup.exe	Potential ransomware staging executable
File	hfs.exe	Potential ransomware staging executable
File	Wireshark-win64-4.0.4.exe	Potential ransomware staging executable
File	git.exe	Potential ransomware staging executable
File	WinSCP-5.19.5-Setup.exe	Potential ransomware staging executable
File	GeoServer-2.24.2-winsetup.exe	Potential ransomware staging executable

Recommendations

Critical (48-72 hours)

1. Immediate Credential Reset Business Risk: Unauthorized access to sensitive systems and data. **Technical Description:** Reset all credentials, especially those with administrative privileges, to prevent further unauthorized access. **MITRE Mitigation ID:** M1026 **2. Remove Direct RDP Exposure Business Risk:** Direct exposure of RDP services increases the risk of unauthorized access. **Technical Description:** Disable direct RDP access from external networks and implement VPN or secure gateways for remote access. **MITRE Mitigation ID:** M1021 **3. Block Known Exfil Services Business Risk:** Continued data exfiltration can lead to data breaches and loss of sensitive information. **Technical Description:** Block access to known exfiltration services such as 'temp.sh' at the firewall and DNS level. **MITRE Mitigation ID:** M1030

High Priority (1-2 weeks)

1. Segment Remote Access Business Risk: Unsegmented remote access can facilitate lateral

movement by attackers. **Technical Description:** Implement network segmentation to isolate remote access points from critical systems. **MITRE Mitigation ID:** M1030 **2. Implement Privileged Access Management (PAM) Business Risk:** Uncontrolled administrative access can lead to privilege escalation. **Technical Description:** Deploy PAM solutions to manage and monitor privileged accounts and access. **MITRE Mitigation ID:** M1026 **3. Harden Backup Access Business Risk:** Unauthorized access to backup systems can lead to data loss or manipulation. **Technical Description:** Restrict access to backup systems and implement multi-factor authentication for backup operations. **MITRE Mitigation ID:** M1042 **4. Enforce East-West Segmentation Business Risk:** Lack of segmentation allows attackers to move laterally within the network. **Technical Description:** Implement micro-segmentation to control east-west traffic and limit lateral movement. **MITRE Mitigation ID:** M1030

Medium Priority (1-3 months)

1. Deploy Comprehensive Monitoring Business Risk: Lack of visibility into network activities can delay detection of malicious actions. **Technical Description:** Deploy network and endpoint monitoring solutions to detect and respond to suspicious activities. **MITRE Mitigation ID:** M1018 **2. Strengthen Credential Hygiene Business Risk:** Weak or compromised credentials can lead to unauthorized access. **Technical Description:** Enforce strong password policies and regular password changes to enhance credential security. **MITRE Mitigation ID:** M1027 **3. Deploy Data Loss Prevention (DLP) Business Risk:** Uncontrolled data exfiltration can result in data breaches. **Technical Description:** Implement DLP solutions to monitor and control data transfers and prevent unauthorized exfiltration. **MITRE Mitigation ID:** M1030 **4. Restrict SAMR/LSARPC Business Risk:** Unrestricted access to SAMR/LSARPC can facilitate credential theft. **Technical Description:** Restrict access to SAMR and LSARPC services to prevent unauthorized credential access. **MITRE Mitigation ID:** M1042

This report provides a comprehensive analysis of the ransomware incident at SC4063 Network Security, detailing the attack vectors, evidence, and recommended actions to mitigate future risks. Immediate implementation of critical recommendations is essential to secure the network and prevent further compromise.